SecureWealth Twin — High-Level Architecture

Punjab & Sind Bank Hackathon Series 2026 · Requests flow downward; no investment reaches the database without a decision

CLIENTS

presentation only — no security logic

Mobile app · React Native
Customer journey in English, Hindi and Punjabi
Consent gate, step-up verification, phishing scan

Admin dashboard · browser
Overview, audit console, investments
Red-team console (10 live attack scenarios)

↓ *HTTPS · bearer token per request*

API · FastAPI + Pydantic v2

stateless — scales horizontally behind a load balancer

- **Auth & sessions** — MPIN hashed bcrypt
- **Aggregation** — consent-gated 403 without it
- **Transactions** — investment initiate / verify
- **Security** — challenge, method switch
- **AI** — wealth + explainability
- **Audit** — chain, integrity, replicas
- **Admin** — stats, search, red team

↓ *every investment, before any money moves*

SECURITY PIPELINE

risk weights sum to 1.0 — asserted at import

Behaviour engine
8 signals: amount spike, velocity, OTP timing, night

Fraud ML · XGBoost
22 features
weight 0.35

Zero-day · autoencoder
reconstruction error
vs p95 / p99

Risk engine
behaviour 0.25 · device 0.25
environment 0.15

Decision
ALLOW · WARN
CHALLENGE · BLOCK

↓ *decision recorded, then explained*

INTELLIGENCE

local LLM — customer data never leaves the bank network

Wealth engine
Priority ladder: suppress → emergency fund → debt → idle cash → growth. Mutual funds and deposits only

7 explainability engines
Wealth, fraud, decision, challenge, unknown-risk, device trust, phishing — plain language, 3 languages

Ollama · llama3
On-premise generation
Deterministic templates as fallback

↓ *signed, hash-linked, replicated*

DATA & AUDIT · PostgreSQL

background sweep re-verifies the whole chain every 300 s

Operational tables
users, accounts, transactions, deposits, loans, devices

audit_logs (master)
one record per decision — including every ALLOW

replica 1 / 2 / 3
independent copies
for repair, not just detection

Hash chain + Ed25519
authority = valid signature, not content majority

KEY DESIGN DECISIONS

Fraud judged in-line
Decided before settlement, not reconciled afterwards.

Signature over majority
An insider rewriting 3 of 4 copies still loses to the 1 they missed.

Explanations cannot decide
The language model reads the verdict; it sits outside the critical path.

Uncertainty escalates
A pattern the models have not seen resolves to CHALLENGE, never a silent ALLOW.